

purdue-l35-it-ot-boundary brief

Purdue IT/OT Boundary (Level 3.5 — Industrial DMZ) — Cross-Vendor Threat & Detection Brief

Scope: Purdue Level 3.5 is the Industrial DMZ — the brokered crossover zone between corporate IT (Level 4) and the OT operations zone (Level 3 process supervisory and below). It hosts industrial firewalls, managed industrial Ethernet switches, jump hosts, AV/WSUS/patch relays, remote-access gateways, KVM/console servers, and the network management cards (NMCs) that front power infrastructure (UPS, rack PDU). This brief cross-cuts Belden/Hirschmann, Rockwell (Stratix), Schneider (ConneXium, EcoStruxure Secure Connect), Siemens (SCALANCE, RUGGEDCOM, SINEMA RC), Moxa, APC, Eaton, Vertiv (Avocent + IntelliSlot), Lantronix, Opendgear, and Tosibox. L3.5 is the **most common foothold layer for external attackers** — almost every public ICS intrusion since 2015 (Industroyer, TRITON, Volt Typhoon pre-positioning) traversed an L3.5 device on the way in.

Architecture grouping (organized by ROLE within this layer, not by vendor)

Class (role)	Products (cross-vendor)	Stack (RTOS / protocol / OS)	Catalog depth
Industrial firewall	Belden/Hirschmann Tofino Xenon; Rockwell Stratix 5950 (Cisco ASA/FTD OEM); Schneider ConneXium TCSEFEC; Siemens SCALANCE S612/S615/S623/S627/SC646	VxWorks / Linux / proprietary; IPsec, OPC inspection, Modbus/DNP3 DPI	Vendor PSIRT only
Industrial Ethernet switch	Rockwell Stratix 5700/5400/5410/5800/8000/8300 (Cisco IE OEM, IOS / IOS-XE); Siemens SCALANCE X-200/X-300/XB-208; Siemens RUGGEDCOM RX1500/RSG2300 (ROS / ROX II); Schneider ConneXium TCSESM; Moxa EDS-series	Cisco IOS/IOS-XE, Siemens ROS/ROX, Linux	Inherits Cisco IOS CVE stream + per-vendor PSIRT
Network management card (power infra)	APC NMC2 AP9630/9631/9635, NMC3 AP9640/9641/9643, Rack PDU 2G AP86xx; Eaton Network-M2/M3, Industrial-Gateway-M3, ConnectUPS; Vertiv IntelliSlot IS-UNITY-DP and legacy IntelliSlot	VxWorks 5.x/6.x/7 (APC, Eaton M2); embedded Linux (Eaton M3, Vertiv IS-UNITY); HTTP(S), SNMP v1/v2c/v3, Modbus/TCP, BACnet/IP, NTP	Catalogued — per-vendor briefs exist

Class (role)	Products (cross-vendor)	Stack (RTOS / protocol / OS)	Catalog depth
KVM / console server	Vertiv Avocent ACS 8000; Lantronix SLB; Opengear IM7200	Embedded Linux; telnet/SSH/HTTPS console multiplexing, serial-over-IP	Research only
Jump host / AV / WSUS relay	Windows Server, RHEL/Ubuntu inside DMZ subnet	Windows / Linux; RDP, SMB, WSUS HTTPS, EDR agents	Windows CVE stream
Remote-access gateway	Schneider EcoStruxure Secure Connect Advisor; Siemens SINEMA Remote Connect Server/Client; Tosibox Lock	Linux appliance; OpenVPN / IPsec / WireGuard, MQTT broker	Vendor PSIRT only
Power-infrastructure MCU (cross-cut)	Eaton bare-metal UPS MCUs (Callisto chipset .sta firmware); Eaton ePDU controllers; APC Smart-UPS internal MCUs; Vertiv Liebert GXT5 controllers	Cortex-M / proprietary RTOS; serial UART to NMC	Research only — armor surface for TLStorm-class attacks

Group 1 — Industrial firewall

Direct attack surface: management plane (HTTPS GUI / SSH CLI / SNMP), site-to-site IPsec, OPC Classic/UA inspection engines, Modbus/DNP3 deep-packet-inspection rules, firmware update channel. The Stratix 5950 directly inherits the Cisco ASA/FTD CVE stream; SCALANCE S inherits the Siemens ProductCERT cycle.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2023-20269	9.1	Rockwell (Cisco OEM)	Stratix 5950	ASA/FTD VPN brute-force unauthenticated
CVE-2024-20353	8.6	Rockwell (Cisco OEM)	Stratix 5950	ArcaneDoor — ASA web-server DoS
Siemens SCALANCE SC-600 family advisories	varies	Siemens	SCALANCE S615/SC646	multiple — see ProductCERT monthly cycle
Schneider PSIRT ConneXium	varies	Schneider	ConneXium TCSEFEC	firmware update + management-plane class

Top attack vector (MITRE ATT&CK ICS): [T0866 Exploitation of Remote Services](#) against the firewall's own management plane, followed by [T0830 Adversary-in-the-Middle](#) of the inspected OT protocols.

Group 2 — Industrial Ethernet switch

Direct attack surface: Cisco-stack switches (Stratix) expose IOS/IOS-XE CLI/HTTP/HTTPS/SNMP, Smart Install client on TCP/4786, CDP, LLDP. Siemens SCALANCE/RUGGEDCOM ROS exposes web UI, SSH, SNMP, PROFINET DCP, and the RUGGEDCOM ROS-specific maintenance services. Backdoored switch firmware (Lumen Black Lotus Labs 2022 ZuoRAT-class research) gives an attacker the ability to mirror or tap all traffic crossing L3.5.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2018-0171	9.8	Rockwell (Cisco OEM)	Stratix IOS Smart Install	unauth RCE on TCP/4786
CVE-2023-20198	10.0	Rockwell (Cisco OEM)	Stratix 5800/8300 (IOS-XE)	web UI auth bypass — privilege 15
CVE-2023-20273	7.2	Rockwell (Cisco OEM)	Stratix IOS-XE	implant install chained with CVE-2023-20198
RUGGEDCOM ROS advisories	varies	Siemens	RUGGEDCOM RX1500/RSG2300	management-plane, ROS web UI
SCALANCE X-series ProductCERT	varies	Siemens	SCALANCE X-200/X-300	recurring web/SNMP class

Top attack vector (MITRE ATT&CK ICS): [T0859 Valid Accounts](#) (default/shared SNMP community + RADIUS shared secret) chained with [T0830 Adversary-in-the-Middle](#) via SPAN/mirror reconfiguration.

Group 3 — Network management card (power infra)

Direct attack surface: HTTPS GUI, SSH, telnet (legacy), SNMP v1/v2c/v3, Modbus/TCP on TCP/502, BACnet/IP on UDP/47808, NTP client on UDP/123, firmware-update channel (TFTP / HTTPS / FTP). These cards are routinely **internet-exposed** (CISA flagged this in AA22-082A, March 2022) and accept power-cycle commands authenticated only by SNMP community string or web session.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2022-22805	9.0	APC (Schneider)	NMC2 / NMC3	TLStorm — TLS reassembly buffer overflow → RCE
CVE-2022-22806	9.0	APC (Schneider)	NMC2 / NMC3	TLStorm — TLS authentication bypass
CVE-2022-0715	8.9	APC (Schneider)	NMC2 / NMC3	TLStorm — unsigned firmware update
Eaton PSIRT — Network-M2/M3 advisories	varies	Eaton	Network-M2 / Network-M3	NTP-server-config injection + firmware-upgrade MITM class (see vendor PSIRT)
Eaton PSIRT — UPS Companion advisories	varies	Eaton	UPS Companion (Windows host installer)	DLL hijack class on Windows host
Vertiv IS-UNITY-DP advisories	varies	Vertiv	IntelliSlot IS-UNITY-DP	management-plane class

Top attack vector (MITRE ATT&CK ICS): [T0883 Internet Accessible Device](#) → [T0857 System Firmware](#) via the TLStorm/Eaton firmware-tamper chain, terminating in [T0813 Denial of Control](#) by power-cycling the protected rack.

Group 4 — KVM / console server, jump host, AV/WSUS relay

Direct attack surface: RDP/SSH/HTTPS to jump host; WSUS HTTP(S) on TCP/8530 and TCP/8531; Avocent ACS historical telnet/SSH/HTTP; AD trust between L4 forest and L3.5 service accounts; EDR-blind serial-over-IP sessions to L2/L1 equipment. Jump hosts that are domain-joined to the L4 corporate forest are the **single largest L4→L3.5 risk** in CISA Volt Typhoon AA24-038A.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
Volt Typhoon AA24-038A	n/a (campaign)	n/a	Windows DMZ jump hosts	LOLBins, valid accounts, pre-positioning
CVE-2020-1472 Zerologon	10.0	Microsoft	DMZ-joined DC / jump host	Netlogon bypass
CVE-2022-30190 Follina	7.8	Microsoft	WSUS/jump host MS Office	MSDT URL handler
Vertiv Avocent ACS PSIRT	varies	Vertiv	Avocent ACS 8000	management-plane, historical telnet/HTTP

CVE	CVSS	Vendor	Product	Vector
Opendgear advisories	varies	Opendgear	IM7200	management-plane class

Top attack vector (MITRE ATT&CK ICS): [T0822 External Remote Services](#) (VPN into jump host) → [T0859 Valid Accounts](#) on the OT-side AD trust.

Group 5 — Remote-access gateway

Direct attack surface: OpenVPN/IPsec/WireGuard tunnel endpoints, MQTT broker to cloud, vendor SaaS plane (Schneider EcoStruxure, Siemens SINEMA RC cloud), client-side enrolment flow, certificate-issuance flow.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
Schneider EcoStruxure Secure Connect PSIRT	varies	Schneider	EcoStruxure Secure Connect Advisor	enrolment / cloud plane class
Siemens SINEMA RC ProductCERT	varies	Siemens	SINEMA Remote Connect Server	recurring web-UI + tunnel class
Tosibox advisories	varies	Tosibox	Lock	management-plane class

Top attack vector (MITRE ATT&CK ICS): [T0822 External Remote Services](#) — abuse of a legitimately enrolled vendor tunnel, especially after L4 EDR compromise of an engineer's laptop holding the client certificate.

Logging matrix (highest priority for this layer)

Priority	Source	Event	What it catches	MITRE ATT&CK ICS
1	Industrial firewall syslog	Allow rule added/modified, new ACL on management VLAN	Attacker pre-staging an exfil or C2 hole through the DMZ boundary	T0884 Connection Proxy
2	Stratix / SCALANCE / RUGGEDCOM syslog	SPAN/mirror session created or modified	Managed-switch wiretap of OT protocol traffic	T0830 Adversary-in-the-Middle

Priority	Source	Event	What it catches	MITRE ATT&CK ICS
3	NMC HTTP / SNMP audit (APC / Eaton / Vertiv)	Firmware upload, outlet group power-off, NTP-server-config write	TLStorm-class firmware tamper or single-packet rack power-off	T0857 System Firmware / T0813
4	Jump-host Windows Security log	4624 type-10 RDP from L4 subnet, 4672 special privileges assigned	Lateral move L4 → L3.5 via valid accounts (Volt Typhoon pattern)	T0859 Valid Accounts
5	Cisco IOS-XE web UI auth log	privilege-15 account created via web UI without TACACS record	CVE-2023-20198 Stratix implant install	T0866 Exploitation of Remote Services
6	Remote-access gateway audit (SINEMA RC / EcoStruxure SC / Tosibox)	New client enrolment, certificate re-issuance, new tunnel to unknown peer	Stolen vendor-tunnel credential from compromised engineer laptop	T0822 External Remote Services
7	Network flow (Zeek/Suricata at L3.5 ↔ L3 hinge)	New L3.5 host initiating SNMP-set, Modbus-write (TCP/502), or CIP-write (TCP/44818) into L3	Pivot into operations zone from a compromised DMZ host	T0855 Unauthorized Command Message
8	WSUS / AV-relay logs	Out-of-band update package signed by non-vendor key, manual approval by service account	Supply-chain push into OT via patch relay	T0862 Supply Chain Compromise

Secondary: RUGGEDCOM ROS / SCALANCE event log (boot, config change), Stratix `archive log config` notifies, APC NMC event.txt + data.txt, Eaton Network-M2/M3 syslog forwarder, Vertiv IntelliSlot trap log, Avocent ACS audit, Tosibox connection ledger, NetFlow/sFlow asymmetry, ARP-table anomalies at the L3.5 boundary, MAC-flap on inter-VLAN trunks.

Cross-layer pivots

1. **L4 → L3.5 via jump host VPN.** Compromised engineer laptop in L4 (phish or stolen MFA-fatigue session) → corporate VPN → RDP into DMZ jump host → re-use of shared service account into OT-side AD trust. This is the canonical Volt Typhoon AA24-038A pre-positioning chain and resembles the entry path used in TRITON's reconstructed timeline.

2. **L4 → L3.5 → L1/L0 via internet-exposed NMC.** Direct internet exposure of APC NMC, Eaton Network-M2/M3 or Vertiv IS-UNITY-DP (CISA AA22-082A, March 2022) → TLStorm CVE-2022-22805/22806/0715 or an Eaton Network-M2/M3 PSIRT advisory → single SNMP-set or HTTPS POST sends `OutletGroupOff` to the rack PDU → unscheduled power-off of the PLCs and HMIs in the cabinet. No L3 access required; the NMC is the weapon.
3. **L3.5 → L3 via SNMP write to SCADA management interface.** Compromise of a Stratix or SCALANCE switch with default/shared SNMP community ([T0812 Default Credentials](#)) → SNMP-set against a SCADA server's NIC management interface or an OPC server VM's vCenter agent → reconfigure default gateway or DNS → covert MITM of supervisory traffic for [T0832 Manipulation of View](#).
4. **L3.5 → L3 via shared AD trust.** Jump host or AV/WSUS relay domain-joined to both the corporate forest (L4) and an OT child domain (L3) → Kerberoasting or DCSync against the OT child domain → valid-account login to the engineering workstation → Evil-PLC weaponized project file delivered to the PLC at L1 via [T0843 Program Download](#).
5. **L3.5 switch backdoor → traffic mirror to attacker C2.** Backdoor implant (Lumen Black Lotus Labs 2022 ZuoRAT-class research) on a Stratix or SCALANCE switch → covert SPAN port → DNP3 (TCP/20000) / Modbus (TCP/502) / IEC 61850 MMS (TCP/102) traffic mirrored over the firewall via a permitted outbound flow → adversary reconstructs the process model offline, enabling later [T0831 Manipulation of Control](#) (Industroyer/Industroyer2 pattern).

Sources

- [CISA ICSA-22-083-01 — APC TLStorm](#)
- [Armis TLStorm research](#)
- [CISA AA22-082A — Internet-Exposed UPS Devices \(March 2022\)](#)
- [CISA AA24-038A — Volt Typhoon pre-positioning](#)
- [NVD CVE-2022-22805 · CVE-2022-22806 · CVE-2022-0715](#)
- [Eaton PSIRT — Network-M2/M3 and UPS Companion advisories](#)
- [NVD CVE-2023-20198 — Cisco IOS-XE web UI · CVE-2023-20273 · CVE-2018-0171 Smart Install · CVE-2023-20269 · CVE-2024-20353 ArcaneDoor](#)
- [NVD CVE-2020-1472 Zerologon · CVE-2022-30190 Follina](#)
- [Siemens ProductCERT — SCALANCE and RUGGEDCOM ROS monthly advisory cycle](#)
- [Schneider PSIRT — security notifications portal](#)
- [Rockwell Automation Trust Center — Stratix advisories](#)
- [Vertiv security advisories portal — Avocent ACS, IntelliSlot IS-UNITY](#)
- [Opendgear security advisories · Tosibox security · Belden/Hirschmann PSIRT](#)
- [Lumen Black Lotus Labs — ZuoRAT / managed-router and switch backdoor research \(2022\)](#)
- [Claroty Team82 research](#)
- [Dragos blog — Industroyer / Industroyer2 / PIPEDREAM analysis](#)
- [Forescout Vedere Labs — OT:ICEFALL](#)

- MITRE ATT&CK ICS techniques: [T0812](#) · [T0813](#) · [T0822](#) · [T0830](#) · [T0831](#) · [T0832](#) · [T0843](#) · [T0855](#) · [T0857](#) · [T0859](#) · [T0862](#) · [T0866](#) · [T0883](#) · [T0884](#)
- Purdue Model reference: [ISA-95](#) · [ISA/IEC 62443](#)